

REPORT DI ANALISI STATICA DEL MALWARE

LABORATORIO DI ANALISI MALWARE E SICUREZZA OFFENSIVA

Analista:	Leandro Ancona	Data Analisi:	3 Giugno 2026
Target File:	notepad-classico.exe	Ambiente:	FlareVM (Isolato)
Metodologia:	Analisi Statica (PE Analysis)	Piattaforma:	Epicode Institute of Technology

1. Introduzione ed Isolamento dell'Ambiente

In conformità con le best practice di sicurezza informatica applicate all'analisi dei malware, la sessione di esame sul file notepad-classico.exe è stata preceduta da una completa messa in sicurezza della macchina di laboratorio **FlareVM**. L'interfaccia di rete della macchina virtuale è stata configurata in modalità **Host-Only / Disconnessa** per prevenire qualsiasi tipo di esfiltrazione di dati o comunicazioni verso server di Command & Control (C2) esterni, tutelando al contempo l'integrità della rete host e locale. È stata inoltre verificata la presenza di uno snapshot pulito per garantire il ripristino immediato dello stato di sistema.

2. Librerie Importate (Import Directory)

L'analisi della *Import Address Table (IAT)* tramite lo strumento PE-bear ha evidenziato l'utilizzo di diverse librerie dinamiche (DLL). Di seguito viene fornito l'elenco completo delle librerie rilevate all'interno del file binario con la relativa descrizione tecnica delle funzionalità esposte:

KERNEL32.dll

Libreria core del sistema operativo Windows. Gestisce le risorse fondamentali come l'allocazione della memoria (es. VirtualAlloc, LocalAlloc), la manipolazione dei file (es. CreateFileW, ReadFile), il controllo dei processi e dei thread, e la gestione delle eccezioni. Nei contesti malware, è essenziale per allocare spazio in memoria per l'iniezione di codice (shellcode).

Funzioni chiave rilevate: CreateFileW, VirtualAlloc, GetProcAddress, LoadLibraryA, TerminateProcess

USER32.dll

Responsabile della gestione delle componenti dell'interfaccia utente (GUI), come la creazione di finestre, la gestione dei messaggi di sistema, l'intercettazione degli input di mouse e tastiera (es. `GetCursorPos`, `SendMessageW`). Può essere sfruttata da spyware o keylogger per intercettare l'attività dell'utente.

Funzioni chiave rilevate: `LoadStringW`, `GetSystemMetrics`, `LoadImageW`, `SendMessageW`

ADVAPI32.dll

Fornisce l'accesso alle funzioni avanzate del sistema operativo, tra cui la gestione della sicurezza (token di accesso), i servizi di sistema e, in particolare, il **Registro di Sistema di Windows**. Le funzioni come `RegOpenKeyExW` e `RegSetValueExW` sono spesso utilizzate dai malware per garantire la persistenza all'avvio del sistema.

Funzioni chiave rilevate: `RegOpenKeyExW`, `RegQueryValueExW`, `RegSetValueExW`

msvcrt.dll

La libreria di runtime di Microsoft C. Fornisce funzioni standard di manipolazione delle stringhe, allocazione di memoria standard C (`malloc/free`) e operazioni matematiche/I-O di basso livello. È ampiamente utilizzata sia da software legittimi sia da agenti malevoli per l'esecuzione di routine procedurali.

Funzioni chiave rilevate: `_initterm`, `malloc`, `free`, `memcpy`, `strcmp`

SHELL32.dll

Contiene le funzioni relative alle operazioni della Shell di Windows, tra cui l'apertura e l'esecuzione di file esterni o comandi di sistema tramite l'API `ShellExecute` o la gestione dei collegamenti.

comctl32.dll & COMDLG32.dll

Librerie dedicate ai controlli grafici comuni e alle finestre di dialogo standard di Windows (come la finestra "Apri File" o "Salva"). Contribuiscono a conferire al programma l'aspetto visivo di un blocco note legittimo.

GDI32.dll & WINSPOOL.DRV

Gestiscono l'output grafico per i monitor e le stampanti (Graphics Device Interface). Consentono il disegno di testo, font e primitive grafiche sulle finestre dell'applicazione.

3. Sezioni del File Eseguibile (Section Headers)

La struttura del file PE (Portable Executable) analizzato mostra una suddivisione in sezioni standard. La corretta disposizione e i valori di entropia bilanciati indicano che il file non presenta alterazioni macroscopiche da packer o crypter noti in prima istanza:

Nome Sezione	Descrizione e Funzione nell'Analisi del Binario
.text	Codice Eseguibile: Contiene le istruzioni Assembly della CPU destinate all'esecuzione. È tipicamente contrassegnata con i permessi di sola lettura ed esecuzione (RX) per impedire la modifica del codice a runtime.
.data	Dati Inizializzati: Ospita le variabili globali e statiche inizializzate a livello di codice. Può contenere stringhe e configurazioni hardcoded utilizzate dal programma durante il suo ciclo di vita. Permessi tipici: Lettura e Scrittura (RW).
.rsrc	Risorse del Sistema: Contiene gli asset grafici incorporati, quali icone, configurazioni dei menu, stringhe di localizzazione e manifesti di configurazione. Nei file mascherati (trojan), include l'icona dell'applicazione originale (in questo caso l'icona classica di Notepad).
.reloc	Rilocalizzazione: Tabella dei puntatori per il riposizionamento del codice in memoria nel caso in cui l'indirizzo di base preferito (Image Base) non sia disponibile al momento del caricamento (meccanismo ASLR).

Considerazione Finale e Analisi delle Minacce (AI Evaluation)

Sebbene la struttura delle sezioni (.text, .data, .rsrc) e la lista delle librerie importate ricalchino in modo estremamente fedele l'impronta di un'applicazione legittima come il Blocco Note di Windows (garantendo l'efficacia del mascheramento), la presenza contemporanea di importazioni da ADVAPI32.dll dedicate alla manipolazione profonda delle chiavi di registro (RegSetValueExW) e di KERNEL32.dll con funzioni di manipolazione della memoria e dei processi richiede estrema attenzione. In un contesto di attacco, questo binario si comporta come un **Trojan Horse**: attira l'utente mostrando un'interfaccia familiare, mentre in background esegue routine di persistenza o scarica payload aggiuntivi sfruttando i privilegi del sistema.